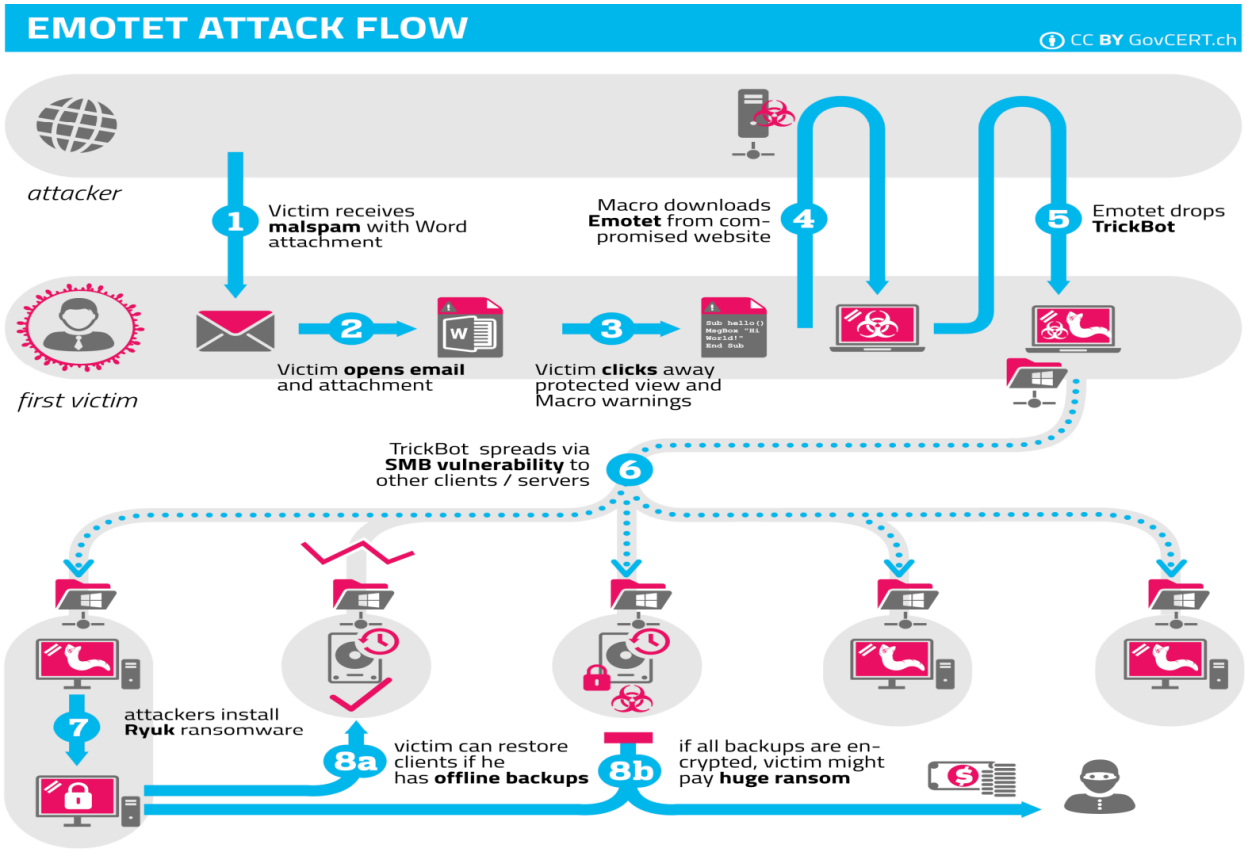
Social Engineering

Description

Studia come influenzare il comportamento individuale di un utente per carpire informazioni utili.

Spear phishing: attacco mirato ad una persona dopo aver ottenuto informazioni per specializzare attacco



Bad enginenring

La ***bad engineering*** (ingegneria scadente) è un concetto che descrive pratiche di progettazione, sviluppo, implementazione e gestione di sistemi, software o

soluzioni tecniche che sono inefficaci, mal progettate o addirittura dannose.

È il risultato di errori tecnici, decisioni sbagliate, mancanza di buone pratiche o di attenzione ai dettagli.

Nel contesto dello sviluppo software, la bad engineering può manifestarsi in vari modi:

1. **Codifica scadente**: Scrivere codice che è difficile da mantenere, mal organizzato o che non segue i principi di progettazione consolidati (come la separazione delle preoccupazioni, il riutilizzo del codice e la modularità). Un esempio tipico è l'uso di codice "spaghetti", che rende la manutenzione e l'estensione del sistema complessa e costosa.
2. **Scarsa gestione della qualità**: La mancanza di testing adeguato o di una solida strategia di gestione della qualità può portare a software pieno di bug e vulnerabilità. In molti casi, non vengono seguiti test unitari, integrazione continua o altre buone pratiche di sviluppo.
3. **Decisioni progettuali sbagliate**: Queste includono scelte di architettura o di design che non sono scalabili, che non ottimizzano le prestazioni o che non tengono conto dei requisiti futuri del sistema. Per esempio, l'adozione di tecnologie obsolete o non adatte alle esigenze del progetto.
4. **Mancanza di manutenzione**: La bad engineering può derivare anche dalla scarsa attenzione alla manutenzione del sistema nel lungo periodo. Quando il codice o il sistema non vengono aggiornati, o se non vengono risolte le problematiche conosciute, il sistema si degrada nel tempo e diventa più vulnerabile a guasti e attacchi.
5. **Cattiva gestione della sicurezza**: Una delle aree più critiche della bad engineering è la sicurezza. Ad esempio, l'uso di pratiche di codifica vulnerabili, come la mancata gestione corretta delle credenziali, la protezione insufficiente dei dati sensibili, l'assenza di misure di protezione contro attacchi comuni (SQL injection, Cross-Site Scripting, ecc.), può portare a rischi significativi per l'integrità e la riservatezza dei dati.
6. **Scarsa comunicazione tra i team**: La mancanza di collaborazione tra i diversi team (sviluppo, sicurezza, test, ecc.) può portare a soluzioni incomplete o

incoerenti, con difetti che non vengono rilevati durante il ciclo di vita del progetto.

Esempi concreti di bad engineering includono:

- **Software con vulnerabilità di sicurezza** non risolte, che espone i dati degli utenti a rischi.
- **Sistemi che non sono scalabili**, che falliscono quando il numero di utenti aumenta.
- **Performance scarse** in applicazioni o siti web che non sono ottimizzati, rallentando l'esperienza dell'utente.
- **Documentazione insufficiente** che rende difficile per i nuovi sviluppatori o team lavorare sul progetto.

Analisi degli impatti

Calcola il danno che un attaccante può causare quando una intrusione ha successo

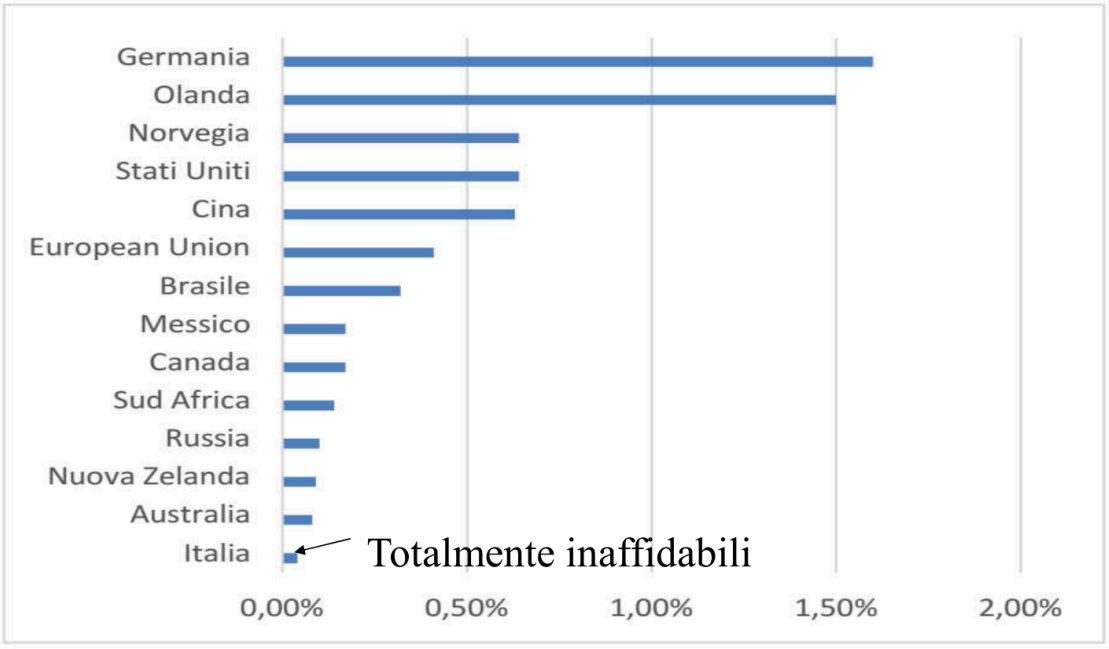
- Richiede quindi di ricostruire possibili intrusioni
- Danno è dato dalla somma di un insieme di costi
- Ripristino di uno stato corretto
- Ricostruzione informazioni perse
- Perdita di produzione
- Informare i possessori dei dati (privacy)
- Danno di immagine

Quali sono le voci di costo più elevate per le aziende che hanno subito una intrusione?

1. 39% del costo complessivo è dovuto all’impatto economico della Business Disruption = non è possibile lavorare per blocco del SI

2. 35% del costo è dovuto al danno per la perdita di informazioni, che include i costi di
    a. notifica di un data breach ai clienti GDPR,
    b. rimborso ai clienti delle spese per il controllo del credito
    c. distribuzione di nuove carte di credito in caso di furto del numero della carta,
    d. costi per multe e spese legali associate al furto dei dati (class action, cause
    intentate all'azienda).
3. 21% del costo è dovuto a a perdita di fatturato, dovuta principalmente al danno di reputazione.

Incidenza del cybercrime sul PIL dei principali paesi



Contromisure

Modifiche ai componenti utilizzati, poco costose in fase di progetto, molto costose dopo

Aggiunta di componenti progettati per

- Eliminare le vulnerabilità (patch, controlli compensativi, migliore gestione dei diritti degli utenti)
- Filtrare le connessioni (firewall con insieme di regole per decidere se una certa comunicazione può avvenire)
- Individuare malware (endpoint protection)
- Scoprire intrusioni e fermare attacchi (intrusion detection system, intrusion prevention system, security and information event monitoring)

Possono operare in modo

- **Statico:** cambiano permanentemente il sistema per eliminare vulnerabilità
- **Dinamico:**cambiano il sistema quando è in corso una intrusione per fermare le varie azioni
  (in generale attacchi)

> 💡 *Le contromisure dinamiche richiedono un monitoraggio del sistema IDS + Gestione di rete*

Confronto tra rischi

Il rischio dipende da due fattori:

1. Danno di una intrusione che ha successo
2. Probabilità che l'intrusione avvenga ed abbia successo

Se il rischio è molto più basso del costo delle contromisure lo si può accettare ed il sistema non viene modificato

Se il rischio è troppo alto lo si può ridurre:

- Trasferendolo ad un costo fisso (perdita fissa) = assicurazione
- Modificando il sistema adottando delle contromisure che eliminano una o più vulnerabilità diminuendo o annullando la probabilità di successo di alcuni attacchi e quindi dell'intrusione
- Riducendo danno di intrusione eg cifro database
- Abbandonando il sistema

